

PeerLink KACST Session Control Test Record

Classification: Internal working evidence; sanitize before external submission **Control:** Session idle timeout and absolute lifetime **Release ID:** OCI production application `c525585` ; final deployed verification `bdb03b5` (workflow `31539611417`)
Implementation date: 2026-08-11 AST **Environment:** Isolated acceptance plus OCI production
`https://p2p.iiotsolutions.sa` **Tester / reviewer:** Nemo automated acceptance and production verification;
Hamza/Aadil sign-off pending

Sanitized Configuration Evidence

Evidence ID	Required capture	Status
SC-CONFIG-01	Backend values: idle 30 minutes and absolute 8 hours	Production runtime verified by workflow run <code>31531595809</code>
SC-CONFIG-02	SuperTokens values: access 1,800 seconds, refresh 480 minutes	Deployed through production Compose and SuperTokens 11.3.7
SC-CONFIG-03	Frontend value: idle 30 minutes	Deployed production source/build verified; isolated browser stack used 45 seconds for behavioral acceptance
SC-COOKIE-01	Production cookie policy requires <code>Secure</code> , <code>HttpOnly</code> , and <code>SameSite=Lax</code> ; values redacted	Production runtime configuration verified; optional sanitized browser-cookie metadata capture remains pending

Acceptance Test Matrix

Record timestamps in AST (UTC+3). Never paste a usable cookie or token.

Test ID	Role	Procedure	Expected result	Actual result	Pass/Fail	Evidence reference
SC-IDLE-USER	Normal user	Sign in, record time, leave browser and account inactive for 30 minutes, then request a protected page/API	Session is rejected and a new sign-in is required	Accelerated server boundary covered; real-duration production run pending	Local Pass	Acceptance script + unit boundary test
SC-IDLE-ADMIN	Administrator	Repeat normal-user idle test using an administrator	Same 30-minute expiry	Disposable administrator rejected after accelerated 45-second idle period	Pass	<code>run_session_control_acceptance.py</code> output, 2026-08-11
SC-ACTIVITY-USER	Normal user	Remain active with genuine interactions before 30 minutes	Session remains usable before absolute limit	Disposable member stayed valid during six authenticated heartbeats	Pass	Acceptance script, 25-second heartbeat intervals
SC-ABS-USER	Normal user	Maintain controlled activity until eight hours from session creation, then request protected resource	Session expires at eight hours despite activity	Disposable member rejected at accelerated 150-second absolute boundary despite activity	Pass	Acceptance script + exact 8-hour unit boundary test
SC-ABS-ADMIN	Administrator	Repeat absolute-lifetime test using an administrator	Same eight-hour expiry	Exact role-independent 8-hour calculation covered by global policy unit test; real-duration production run pending	Local Pass	Unit test/global recipe enforcement
SC-LOGOUT-USER	Normal user	Sign in, log out, then replay a protected request from the same browser	Active session is revoked; protected request fails	Standard SuperTokens sign-out followed by token replay returned 401	Pass	Acceptance script

Test ID	Role	Procedure	Expected result	Actual result	Pass/Fail	Evidence reference
SC-LOGOUT-ADMIN	Administrator	Repeat logout test using an administrator	Active session is revoked	Global role-independent sign-out path covered; production role replay pending	Local Pass	Shared SuperTokens recipe
SC-ROTATE-01	Either	Observe sanitized cookie metadata before and after a normal refresh	SuperTokens refresh succeeds only while policy remains valid; token value rotates	Refresh succeeded, both tokens rotated, and rotated access remained authorized; values never printed	Pass	Acceptance script
SC-CROSS-TAB-01	Either	Open two tabs, remain inactive, observe expiry	Tabs share inactivity state and account is signed out	Shared <code>localStorage</code> event implementation, TypeScript build, targeted lint, and browser render verified; two-tab production capture pending	Local implementation pass	Hook source/build + BrowserOps task
SC-DISTRIBUTED-01	Either	If multiple backend instances exist, authenticate through one and validate expiry through another	Shared session state prevents bypass	Production runs four backend workers against shared SuperTokens/PostgreSQL state; distributed unit path passed in deployed image	Pass	Run 31531595809 + architecture evidence
SC-LEGACY-01	Either	Use a pre-deployment session outside the new idle limit after deployment	Existing session fails closed and requires sign-in	Fail-closed legacy-session test passed inside deployed production image	Pass	Run 31531595809 , 32 deployed-image tests

Automated Verification Completed

Check	Result
Idle boundary calculation at 30 minutes	Pass
Absolute boundary calculation at 8 hours	Pass
Absolute limit cannot be extended by recent activity	Pass
Expired session is revoked	Pass
Activity is persisted while unrelated session data is preserved	Pass
Legacy session without marker fails closed	Pass
Frontend TypeScript and production build	Pass
Backend Python compile	Pass
Production and development Compose validation	Pass
Isolated acceptance Compose validation/startup/health	Pass
Administrator accelerated idle expiration	Pass (45 seconds)
Normal-user accelerated absolute expiration despite activity	Pass (150 seconds)
Refresh-token rotation and post-refresh authorization	Pass
Manual logout and replay rejection	Pass
Browser-rendered isolated frontend	Pass — BrowserOps 20260811-141442-peerlink-session-acceptance-final
Production runtime settings and migration	Pass — workflow 31531595809
Production deployed-image auth/session suite	Pass — 32 tests
Production rendered application health	Pass — BrowserOps 20260811-230228-peerlink-kacst-production-release

Automated checks support the implementation but do not replace post-deployment elapsed-time tests.

Evidence Handling

- Save internal raw evidence under the quarterly package's 05_Raw_Internal_Results/ directory.
- Place only sanitized captures under 04_Security_Control_Evidence/.
- Redact cookie values, session handles, user identifiers, tokens, secrets, internal hostnames, and unnecessary IP addresses.
- Include release ID and exact implementation date before submission.

Exceptions / Limitations

No approved exceptions. Local acceptance and production deployment are complete. A literal role-specific eight-hour wall-clock capture, sanitized production cookie capture, optional two-tab production screenshot evidence, and internal sign-off remain pending. Exact 30-minute/eight-hour boundaries passed deterministically inside the deployed image; no wall-clock result is fabricated.

Sign-Off

Role	Name	Date	Decision
Technical owner	Hamza Feroze	Pending	Pending
Internal reviewer	Aadil Feroze	Pending	Pending

Generated from the approved internal report source for Aadil Feroze's review. Do not forward to KACST without internal approval.